
Risk Register

CSV-backed risk register rendered as professional PDF

Project: Enterprise DevSecOps Security Lab

Author: Jagriti Banerjee

Artifact: risk_register.csv

Assessment Context

Tracks inherent and residual risks across application, container, Kubernetes, supply-chain, GitOps, detection, and audit domains.

Confidentiality: Portfolio lab documentation. Compliance mappings are control-alignment artifacts only and are not formal certifications, attestations, or legal compliance opinions.

1. Risk Register Overview

This document renders the risk_register.csv artifact as an audit-ready risk register. It tracks application security, dependency, container, Kubernetes, supply-chain, GitOps, runtime detection, monitoring, documentation, and exception-management risks identified during the Enterprise DevSecOps Security Lab.

Risk ratings use a qualitative scale: Low, Medium, High, and Critical. Residual risk reflects the risk remaining after implemented controls, compensating controls, or documented exceptions.

Risk Category	Count	Primary Treatment Approach
Application Security	3	Mitigate through implemented controls, retest evidence, and exception tracking.
Dependency Security	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Secrets Management	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Container Security	2	Mitigate through implemented controls, retest evidence, and exception tracking.
Supply Chain	3	Mitigate through implemented controls, retest evidence, and exception tracking.
Kubernetes RBAC	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Kubernetes Runtime	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Kubernetes Network	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Kubernetes Config	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Admission Control	1	Mitigate through implemented controls, retest evidence, and exception tracking.
GitOps	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Detection	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Monitoring	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Compliance	1	Mitigate through implemented controls, retest evidence, and exception tracking.
Exceptions	1	Mitigate through implemented controls, retest evidence, and exception tracking.

2. Detailed Risk Register

Risk ID	Category	Risk Statement	Asset	Inherent	Controls / Treatment	Residual	Owner	Status	Notes
R-001	Application Security	SQL injection in /user route may allow unauthorized data retrieval.	Flask app, SQLite data	L:High I:High S:Critical	Parameterized queries, SAST, AppSec tests, retest plan	L:Low I:Medium S:Medium	Engineering	Remediated/Validated	Retest must confirm injection payload returns no expanded result set.
R-002	Application Security	Command injection in /ping route may allow OS command execution.	Flask app container	L:High I:High S:Critical	Remove shell=True, allowlist host input, SAST, regression tests	L:Low I:High S:Medium	Engineering	Remediated/Validated	Residual risk accepted only for intentionally vulnerable lab branch.
R-003	Application Security	Unsafe template rendering can allow server-side template injection style behavior.	Flask app rendering path	L:Medium I:High S:High	Avoid render_template_string with user input, escape output, test payloads	L:Low I:Medium S:Low	Engineering	Remediated/Validated	Use safe templates and explicit context variables.
R-004	Dependency Security	Outdated packages such as requests may contain known CVEs.	requirements.txt, container image	L:High I:High S:Critical	pip-audit gate, dependency upgrade, SBOM inventory, exceptions process	L:Low I:Medium S:Medium	DevSecOps	Open/Tracked	Accept only if exploitability is documented as not_affected or mitigated.
R-005	Secrets Management	Hardcoded token or key may be committed to repository.	Git repository, CI logs	L:Medium I:High S:High	Trivy secret scan, GitHub secret scanning, least privilege tokens	L:Low I:High S:Medium	DevSecOps	Controlled	All findings require immediate revocation and history review.
R-006	Container Security	Container runs as root and increases impact of compromise.	Docker runtime image	L:Medium I:High S:High	Fixed UID/GID, USER directive, Kubernetes runAsNonRoot	L:Low I:Medium S:Low	Platform	Remediated	Evidence retained from id command and pod security context.
R-007	Container Security	Container image includes critical vulnerability.	GHCR image	L:Medium I:High S:High	Trivy image gate fails critical vulnerabilities; retest after rebuild	L:Low I:Medium S:Medium	DevSecOps	Controlled	Critical image CVE must not be deployed unless formally excepted.
R-008	Supply Chain	Unsigned images may be tampered with before deployment.	Container registry and deployment pipeline	L:Medium I:High S:High	Cosign signing and verification; verifyImages recommended for next phase	L:Low I:High S:Medium	DevSecOps	Partially Remediated	Admission-time signature verification remains future enhancement.
R-009	Supply Chain	Missing SBOM reduces visibility into vulnerable packages.	Container image and dependencies	L:Medium I:Medium S:Medium	Syft SPDX/CycloneDX SBOM generation and retention	L:Low I:Medium S:Low	DevSecOps	Remediated	SBOM must be regenerated on every image build.
R-010	Supply Chain	Weak provenance makes it difficult to prove artifact origin.	Build pipeline, GHCR image	L:Medium I:High S:High	SLSA-style provenance attestation, GitHub Actions provenance recommended	L:Low I:High S:Medium	DevSecOps	Partially Remediated	Local lab provenance is not full SLSA compliance.
R-011	Kubernetes RBAC	ServiceAccount has cluster-admin privilege and can read secrets.	Kubernetes API	L:High I:High S:Critical	Remove ClusterRoleBinding, namespace RoleBinding only, can-i validation	L:Low I:High S:Medium	Platform	Remediated	Periodic RBAC review required.
R-012	Kubernetes Runtime	Privileged pod with hostPath can access node filesystem.	Kind node, workload namespace	L:High I:High S:Critical	Pod Security restricted, Gatekeeper, Falco detection	L:Low I:High S:Medium	Platform	Remediated	Break-glass exceptions must be time-bound.
R-013	Kubernetes Network	Missing NetworkPolicy allows unrestricted pod-to-pod communication.	Kubernetes cluster network	L:Medium I:High S:High	Calico NetworkPolicy default-deny and allowed flows validation	L:Low I:Medium S:Low	Platform	Remediated	All new namespaces should start default-deny.
R-014	Kubernetes Config	Deployment lacks read-only filesystem and dropped capabilities.	Kubernetes workloads	L:Medium I:High S:High	securityContext, readOnlyRootFilesystem, drop ALL, RuntimeDefault seccomp	L:Low I:Medium S:Low	Platform	Remediated	Trivy config scan verifies manifests.

Risk ID	Category	Risk Statement	Asset	Inherent	Controls / Treatment	Residual	Owner	Status	Notes
R-015	Admission Control	Non-compliant workloads can bypass supply-chain labels.	Kubernetes admission	L:Medium I:Medium S:Medium	OPA Gatekeeper required labels policy	L:Low I:Medium S:Low	Platform	Remediated	Next step: enforce Cosign signature policy.
R-016	GitOps	Manual kubectl changes create drift from approved Git state.	Cluster deployment state	L:Medium I:Medium S:Medium	ArgoCD automated sync, prune, selfHeal	L:Low I:Medium S:Low	Platform	Remediated	Self-heal screenshots retained.
R-017	Detection	Falco alerts may not be triaged promptly.	Runtime monitoring stack	L:Medium I:High S:High	Detection report, IR runbook, Prometheus alert rules, Grafana dashboard	L:Low I:High S:Medium	Security	Controlled	Integrate with ticketing or Slack as future improvement.
R-018	Monitoring	Metrics collection failure creates blind spots.	Prometheus/Grafana/Falco	L:Medium I:Medium S:Medium	ServiceMonitor validation, Prometheus target checks, dropped events alerts	L:Low I:Medium S:Low	Security	Controlled	Monitor Falco dropped events and target health.
R-019	Compliance	Evidence is incomplete for audit or recruiter review.	Documentation and reports	L:Medium I:Medium S:Medium	Evidence index, audit summary, control matrix, screenshots	L:Low I:Medium S:Low	Project Owner	Controlled	Maintain evidence naming convention.
R-020	Exceptions	Accepted vulnerabilities persist without expiry.	Vulnerability management process	L:Medium I:High S:High	Vulnerability exceptions and VEX notes with owner/expiry/retest	L:Low I:Medium S:Medium	DevSecOps	Controlled	Expired exceptions are treated as failed gate.

3. Risk Governance Notes

- Critical risks must be remediated or explicitly exception-approved before production-style deployment.
- Accepted risks require an owner, compensating controls, review date, and retest condition.
- Supply-chain exceptions should be paired with VEX notes when exploitability is reduced, not affected, or mitigated.
- Kubernetes exceptions such as privileged pods or cluster-admin access should be time-bound and reviewed as break-glass only.
- Risk closure requires both remediation evidence and retest proof.

References and Alignment Sources

The following references were used as control-alignment sources. The PCI and HIPAA mappings in this portfolio lab are alignment-only and do not represent formal compliance validation, attestation, or certification.

Source	Reference	Use in this document
NIST SSDF	NIST SP 800-218 SSDF v1.1	Secure software development practices used as SDLC control baseline.
OWASP ASVS	OWASP ASVS 5.0.0	Technical verification requirements for application security controls.
CIS Kubernetes Benchmark	Center for Internet Security Kubernetes Benchmark	Consensus-based secure configuration guidance for Kubernetes.
SLSA	Supply-chain Levels for Software Artifacts	Framework/checklist for preventing tampering and improving artifact integrity.
SOC 2 style	AICPA Trust Services Criteria	Control themes aligned to security, availability, confidentiality, and processing integrity.
ISO 27001 style	ISO/IEC 27001:2022	Information security management system control alignment.
PCI alignment only	PCI DSS security requirements	Alignment to protection of cardholder-data environments; no PCI validation claimed.
HIPAA alignment only	HIPAA Security Rule	Alignment to administrative, physical, and technical safeguard themes; no HIPAA compliance opinion claimed.